

# Junior Cloud Security Engineer

## Internship Task Report

|                      |                                                                                          |
|----------------------|------------------------------------------------------------------------------------------|
| Intern Full Name     | Sukhmandeep Kaur                                                                         |
| Intern Email         | [REDACTED]                                                                               |
| Cohort               | Cohort 7                                                                                 |
| Task ID              | CSE-AWS-L-017-04                                                                         |
| Task Title           | Amazon EC2 Security Architecture and Instance Identity Protection                        |
| Skill Domain         | AWS Cloud Security / EC2 Instance Protection                                             |
| Difficulty Level     | Intermediate                                                                             |
| CPE Credits          | 4 CPE Credits                                                                            |
| Guiding Framework(s) | MITRE ATT&CK / AWS Shared Responsibility Model / Least Privilege / Secure Administration |
| Submission Date      | 30 August 2026                                                                           |

## 1.0 Task Overview

|                      |                                                                                                         |
|----------------------|---------------------------------------------------------------------------------------------------------|
| Task ID              | CSE-AWS-L-017-04                                                                                        |
| Task Title           | Amazon EC2 Security Architecture and Instance Identity Protection                                       |
| Skill Domain         | AWS Cloud Security / EC2 Instance Protection                                                            |
| Difficulty           | Intermediate                                                                                            |
| Duration             | 14 Hours                                                                                                |
| CPE Credits          | 4 CPE Credits                                                                                           |
| Cloud Platform(s)    | AWS Free Tier EC2, IAM, Amazon S3, AWS Systems Manager                                                  |
| AWS Region(s) Used   | us-east-2 observed during S3/KMS testing; verify EC2 region before final submission                     |
| Primary Tools        | AWS Console, AWS CLI, SSM Session Manager, curl; AI assistant for explanation and report drafting       |
| Target Environment   | Authorised personal AWS lab account; Amazon Linux 2023 EC2 instance EC2-IMDSv2-Lab; IAM role EC2LabRole |
| MITRE ATT&CK IDs     | T1552.005 (Cloud Instance Metadata API), T1078 (Valid Accounts), T1086 (Execution via API)              |
| Guiding Frameworks   | AWS Shared Responsibility Model; least privilege; secure instance administration                        |
| Regulatory Alignment | General access-control, least-privilege, secure administration, and auditability principles             |

### 1.1 Introduction

This task examined how Amazon EC2 protects instance identity and how temporary role credentials are delivered through the Instance Metadata Service. The lab focused on reducing metadata credential exposure by requiring IMDSv2, using an IAM instance profile instead of static credentials, replacing SSH administration with Systems Manager Session Manager, and applying least-privilege S3 access.

### 1.2 Objectives & Learning Outcomes

The following learning outcomes were achieved through the authorised lab activities:

- Understand EC2 security boundaries and the AWS Shared Responsibility Model — mapped AWS-managed infrastructure controls against customer-managed operating system, IAM, network, application, and metadata settings.
- Explain IMDSv1 versus IMDSv2 and SSRF risk — documented how tokenless metadata requests increased exposure and how IMDSv2 adds a session-token requirement.
- Deploy an EC2 instance with an IAM role and enforce IMDSv2 — configured EC2LabRole and verified the role was attached to EC2-IMDSv2-Lab.
- Explore instance metadata and temporary credentials safely — used IMDSv2 token-based requests and reviewed credential fields without exposing secrets in report evidence.

- Harden access using Session Manager and least privilege — removed/avoided SSH exposure and restricted S3 object access to the designated lab bucket.

### 1.3 Scope & Legal Authorisation

All activities described in this report were performed in an authorised personal AWS lab environment created for the internship task.

Authorised environments used:

- • Personal AWS lab account — Amazon EC2, IAM, Systems Manager, and S3 resources used only for this exercise.
- • EC2 instance: EC2-IMDSv2-Lab with IAM role EC2LabRole.
- • S3 lab bucket: secure-s3-lab-sk, used for authorised read-access and encryption-permission testing.
- • No hosted third-party lab was provided for this task in the material available for this report.

No production environment or real customer data was intentionally accessed. AI assistance was used for explanation, troubleshooting guidance, and report drafting; AWS commands and console changes were executed by the intern. Sensitive credential values are not reproduced in this report.

### 1.4 MITRE ATT&CK Cloud Threat Mapping

| MITRE ATT&CK Technique ID | Technique Name              | Relevance to This Task                                                                                               |
|---------------------------|-----------------------------|----------------------------------------------------------------------------------------------------------------------|
| T1552.005                 | Cloud Instance Metadata API | Directly relevant to attempts to obtain cloud credentials from EC2 metadata; IMDSv2 was enforced to reduce exposure. |
| T1078                     | Valid Accounts              | Temporary instance-role credentials can act as valid AWS credentials within the permissions granted to the role.     |
| T1086                     | Execution via API           | The lab used AWS CLI/API interactions to validate role identity and permitted S3 operations.                         |

## 2.0 Environment & Tool Setup

### 2.1 Cloud Architecture Overview

The lab used a single Amazon Linux 2023 EC2 instance with an attached IAM instance profile. IMDSv2 was required, administrative access was performed through Systems Manager Session Manager, and S3 was used to test the effect of broad versus restricted IAM permissions.

| Cloud Resource / Component | Type / Service      | Role in Task                                                | Region / Config Notes                                                  |
|----------------------------|---------------------|-------------------------------------------------------------|------------------------------------------------------------------------|
| EC2-IMDSv2-Lab             | Amazon EC2          | Target compute instance for metadata and role testing       | Amazon Linux 2023; IMDSv2 required                                     |
| EC2LabRole                 | AWS IAM Role        | Provides temporary credentials to the EC2 workload          | EC2 trust relationship; SSM access retained                            |
| secure-s3-lab-sk           | Amazon S3           | Authorised object-access target for least-privilege testing | Private lab bucket; an object test revealed SSE-KMS decrypt dependency |
| Session Manager            | AWS Systems Manager | Administrative access without inbound SSH                   | AmazonSSMManagedInstanceCore attached                                  |
| Instance Metadata Service  | EC2 IMDSv2          | Provides instance metadata and temporary role credentials   | Token required                                                         |

### 2.2 AWS CLI & Tool Configuration

Tools were used from the AWS Console and from the EC2 Session Manager shell. Exact local version numbers were not captured in the supplied evidence, so the report records only verified tool/service usage.

| Tool / Service      | Version                        | Installation Method                | Purpose in This Task                                                          |
|---------------------|--------------------------------|------------------------------------|-------------------------------------------------------------------------------|
| AWS CLI             | Installed on Amazon Linux 2023 | Available on EC2 instance          | Identity and S3 access testing                                                |
| AWS Console         | Web console                    | No installation required           | EC2, IAM, security group, metadata, S3 configuration                          |
| SSM Session Manager | AWS managed                    | Browser-based session              | Shell access without inbound SSH                                              |
| curl                | System utility                 | Available on instance              | IMDSv2 token and metadata requests                                            |
| AI assistant        | ChatGPT                        | Web application                    | Concept explanation, troubleshooting guidance, reflection and report drafting |
| jq                  | Not verified                   | Not confirmed in supplied evidence | Listed in task tools but not relied on in documented execution                |

Key Configuration Commands Used

Configuration and verification commands included:

```
aws sts get-caller-identity
aws ec2 modify-instance-metadata-options --instance-id <instance-id> --http-tokens required --http-endpoint enabled
TOKEN=$(curl -sS -X PUT "http://169.254.169.254/latest/api/token" -H "X-aws-ec2-metadata-token-ttl-seconds: 21600")
curl -sS -H "X-aws-ec2-metadata-token: $TOKEN" http://169.254.169.254/latest/meta-data/iam/security-credentials/
```

Sensitive values such as account IDs and temporary credentials are intentionally omitted from the report.

2.3 AI Tool Usage Declaration

ChatGPT was used to explain IMDSv1/IMDSv2 concepts, provide troubleshooting guidance, help interpret AWS errors, and draft report language. The intern performed AWS Console changes and CLI commands. AI-generated conceptual material is identified as assistance and should not be represented as independently produced technical evidence where programme rules prohibit that use.

| AI Tool | Used For                                                                                                                | What Was NOT Done with AI                                                                                                                              |
|---------|-------------------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------|
| ChatGPT | Concept explanation; IMDSv2/SSRF summary; troubleshooting AWS CLI/S3/KMS errors; report drafting and reflection support | AI did not log into AWS, execute commands in the AWS account, or create AWS-side configurations. Console and CLI actions were performed by the intern. |

All technical findings, CLI outputs, configurations, and evidence in this report are the intern's own work.

### 3.0 Methodology — Phase Execution

#### Phase A: Theory & Conceptual Foundation

|                  |                                                                                                                                                                              |
|------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Phase Objective  | Understand the architecture of Amazon EC2 security layers including hypervisor isolation, instance identity documents, and metadata service evolution from IMDSv1 to IMDSv2. |
| Estimated Time   | ~90 minutes                                                                                                                                                                  |
| Evidence File(s) | PhaseA_EC2_IdentityFlow.png                                                                                                                                                  |

#### Actions Taken

Reviewed the AWS Shared Responsibility Model and mapped EC2 security boundaries. AWS-managed controls include physical infrastructure and hypervisor/Nitro isolation, while customer-managed controls include the guest OS, application security, IAM permissions, security groups, and IMDS configuration. Studied the historical SSRF risk associated with IMDSv1 and documented the IMDSv2 token-based credential flow.



#### Key Observations

IMDSv2 reduces exposure by requiring a session token before metadata is returned. The exercise also reinforced that instance roles are not inherently unsafe: risk depends on application vulnerabilities, metadata configuration, and the permissions granted to the role.

#### Evidence Produced

- PhaseA\_EC2\_IdentityFlow.png — conceptual EC2 identity and IMDSv2 flow diagram. AI assistance was used in producing the conceptual visual; verify acceptability under programme evidence rules.

#### Phase B: Cloud Environment Setup & Target Preparation

|                  |                                                                                             |
|------------------|---------------------------------------------------------------------------------------------|
| Phase Objective  | Deploy a Free Tier t2.micro instance with an IAM role attached for testing metadata access. |
| Estimated Time   | ~120 minutes                                                                                |
| Evidence File(s) | PhaseB_IMDSv2_Required.png                                                                  |

Actions Taken

Launched the Amazon Linux 2023 instance EC2-IMDSv2-Lab. Created/used EC2LabRole and attached it to the instance; the role included AmazonS3ReadOnlyAccess during the initial test and AmazonSSMManagedInstanceCore for Session Manager. IMDSv2 was configured as required, and administrative access was performed through Systems Manager rather than SSH.



Key Observations

The instance initially showed no IAM role attached, which was corrected through EC2 Actions > Security > Modify IAM role. After attachment, the Security details page showed EC2LabRole. Using Session Manager removed the operational need for an inbound SSH rule.

Evidence Produced

- PhaseB\_IMDSv2\_Required.png — required screenshot showing the instance configured with IMDSv2 required (ensure the final evidence folder contains this screenshot).

Phase C: Core Execution

|                  |                                                                                                      |
|------------------|------------------------------------------------------------------------------------------------------|
| Phase Objective  | Explore the metadata service securely and analyze temporary credentials issued to the instance role. |
| Estimated Time   | ~150 minutes                                                                                         |
| Evidence File(s) | PhaseC_S3_ReadOnly_Test.png (Pending confirmation of successful listing evidence)                    |

Actions Taken

Connected to the EC2 instance through Session Manager and used an IMDSv2 PUT request to obtain a metadata token. The token was then supplied in metadata requests to identify EC2LabRole and inspect the temporary credential document. Credential fields were analysed without reproducing SecretAccessKey or session Token values. S3 read-only access was then tested with the AWS CLI.

```
TOKEN=$(curl -sS -X PUT "http://169.254.169.254/latest/api/token" -H "X-aws-ec2-metadata-token-ttl-seconds: 21600")
curl -sS -H "X-aws-ec2-metadata-token: $TOKEN" http://169.254.169.254/latest/meta-data/iam/security-credentials/
aws s3 ls s3://aws-publicdatasets/
```

Key Observations

The metadata flow confirmed that EC2 workloads can obtain short-lived role credentials without storing static keys. AccessKeyId identifies the temporary credential, SecretAccessKey signs requests, Token identifies the temporary session,

and Expiration limits credential lifetime. A successful Phase C S3 listing screenshot was not supplied in the conversation, so the evidence item remains pending rather than being claimed as complete.

### Evidence Produced

- PhaseC\_S3\_ReadOnly\_Test.png — Pending: required screenshot of successful S3 listing output.

## Phase D: Independent Extension & Advanced Implementation

|                  |                                                                                                  |
|------------------|--------------------------------------------------------------------------------------------------|
| Phase Objective  | Harden your instance by removing SSH access entirely and enforcing least privilege on IAM roles. |
| Estimated Time   | ~120 minutes                                                                                     |
| Evidence File(s) | PhaseD_RestrictedPolicy.json                                                                     |

### Actions Taken

Reviewed the EC2 security group and removed/avoided inbound SSH access because Session Manager was used for administration. Replaced broad S3 read access with a least-privilege inline policy granting only s3:GetObject to arn:aws:s3:::secure-s3-lab-sk/\* . Re-tested object access from the EC2 role. The first object request returned AccessDenied for kms:Decrypt, revealing that the target object was encrypted with a customer-managed KMS key and that S3 permission alone was insufficient for that object.

Restricted policy: Allow s3:GetObject on arn:aws:s3:::secure-s3-lab-sk/\*

Observed test: aws s3 cp s3://secure-s3-lab-sk/text.txt - -> AccessDenied for kms:Decrypt on the object encryption key.

The KMS denial was retained as a troubleshooting observation rather than treated as proof that the permitted S3 object read succeeded.

### Key Observations

Least privilege significantly reduced the blast radius compared with AmazonS3ReadOnlyAccess. The KMS error demonstrated layered authorization: reading an SSE-KMS-encrypted S3 object can require both s3:GetObject and kms:Decrypt. Residual risk remains if the role is granted broader permissions than the workload requires or if application-level SSRF is not addressed.

### Evidence Produced

- PhaseD\_RestrictedPolicy.json — least-privilege policy restricting GetObject to secure-s3-lab-sk/\*.

### Risk Matrix (Phase D Output)



| Cloud Asset / Resource  | Threat / Risk                                                            | MITRE Ref. | Likelihood (1–5) | Impact (1–5) | Score | Rating   |
|-------------------------|--------------------------------------------------------------------------|------------|------------------|--------------|-------|----------|
| EC2 Metadata / IAM Role | Credential exposure through SSRF or metadata abuse                       | T1552.005  | 3                | 5            | 15    | Critical |
| EC2LabRole              | Overly broad S3 read permissions increase credential blast radius        | T1078      | 3                | 4            | 12    | High     |
| S3/KMS object access    | Missing KMS decrypt permission blocks legitimate encrypted-object access | N/A        | 3                | 2            | 6     | Medium   |
| Security Group / SSH    | Exposed SSH would increase remote administration attack surface          | N/A        | 2                | 4            | 8     | Medium   |

*Score = Likelihood × Impact | 1–4: Low | 5–9: Medium | 10–14: High | 15–25: Critical*

## Phase E: Hosted Lab Integration

|                         |                                                                                        |
|-------------------------|----------------------------------------------------------------------------------------|
| <b>Phase Objective</b>  | Hosted lab integration was not included in the task material supplied for this report. |
| <b>Estimated Time</b>   | N/A                                                                                    |
| <b>Evidence File(s)</b> | N/A — no hosted-lab evidence requirement supplied.                                     |

### Actions Taken

No hosted third-party lab activity was provided for Phase E in the task information available for this report. The section is retained because the report template requires every section.

### Key Observations

No hosted-lab observations are claimed.

### Evidence Produced

- N/A — no Phase E

## Phase F: Documentation & Reporting

|                         |                                                                                                                                                |
|-------------------------|------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Phase Objective</b>  | Compile task activities, findings, risk assessment, recommendations, reflections, and evidence references into the internship report template. |
| <b>Estimated Time</b>   | ~60–90 minutes                                                                                                                                 |
| <b>Evidence File(s)</b> | CSE_CSE-AWS-L-017-04_SK_20260830.pdf                                                                                                           |

### Actions Taken

Consolidated Phase A-D actions, evidence references, findings, risk ratings, remediation steps, and reflection answers. Sensitive AWS identifiers and temporary credential values were excluded from the report. Pending evidence was explicitly marked rather than represented as completed.

### Key Observations

The strongest controls demonstrated were IMDSv2 enforcement, temporary role credentials, SSM-based administration, and least-privilege S3 permissions. The KMS AccessDenied result also showed that AWS authorization can involve multiple independent policy layers.

### Evidence Produced

- CSE\_CSE-AWS-L-017-04\_SK\_20260830.pdf — final task report.

## 4.0 Findings

Three significant security observations were documented: metadata credential exposure risk, excessive IAM blast radius before hardening, and the additional KMS authorization requirement encountered during encrypted S3 object access.

### 4.1 Findings Summary

| # | Finding Title                                            | Type / Category                        | Cloud Service / Resource             | MITRE Ref. | Phase | Severity | Evidence Ref.                                              |
|---|----------------------------------------------------------|----------------------------------------|--------------------------------------|------------|-------|----------|------------------------------------------------------------|
| 1 | IMDS credential exposure risk                            | Access Control Weakness                | EC2 IMDS / EC2LabRole                | T1552.005  | A/B   | High     | PhaseA_EC2_IdentityFlow.png;<br>PhaseB_IMDSv2_Required.png |
| 2 | Broad S3 read access increased role blast radius         | IAM Policy Gap                         | IAM Role: EC2LabRole                 | T1078      | B/D   | High     | PhaseD_RestrictedPolicy.json                               |
| 3 | SSE-KMS object required additional decrypt authorization | Access Control / Encryption Dependency | S3 bucket secure-s3-lab-sk / AWS KMS | N/A        | D     | Medium   | Phase D CLI observation                                    |
|   |                                                          |                                        |                                      |            |       |          |                                                            |

### 4.2 Detailed Finding Analysis

Detailed analysis of the three findings follows.

#### Finding 1: IMDS credential exposure risk

|                            |                                                                                                                                                                                                                   |
|----------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Finding Title              | IMDS credential exposure risk                                                                                                                                                                                     |
| Type / Category            | Access Control Weakness                                                                                                                                                                                           |
| Cloud Service / Resource   | Amazon EC2 IMDS / EC2LabRole                                                                                                                                                                                      |
| Description                | If a vulnerable application can reach instance metadata, role credentials may become exposed. IMDSv2 was required so metadata requests need a session token rather than relying on IMDSv1-style tokenless access. |
| How Identified             | AWS Console metadata configuration and IMDSv2 token-based curl workflow.                                                                                                                                          |
| MITRE ATT&CK Reference     | T1552.005 (Cloud Instance Metadata API)                                                                                                                                                                           |
| Business / Security Impact | Compromised temporary credentials could permit AWS API actions within the role permissions, affecting confidentiality and potentially enabling follow-on activity.                                                |
| Severity / Impact          | High                                                                                                                                                                                                              |

|                    |                                                         |
|--------------------|---------------------------------------------------------|
| Evidence Reference | PhaseA_EC2_IdentityFlow.png; PhaseB_IMDSv2_Required.png |
|--------------------|---------------------------------------------------------|

#### Finding 2: Broad S3 read access increased role blast radius

|                            |                                                                                                                                                                                      |
|----------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Finding Title              | Broad S3 read access increased role blast radius                                                                                                                                     |
| Type / Category            | IAM Policy Gap                                                                                                                                                                       |
| Cloud Service / Resource   | IAM Role: EC2LabRole                                                                                                                                                                 |
| Description                | The initial role used AmazonS3ReadOnlyAccess. Phase D replaced this broad access with s3:GetObject limited to objects under arn:aws:s3:::secure-s3-lab-sk/*.                         |
| How Identified             | IAM role policy review and replacement with a restricted inline policy.                                                                                                              |
| MITRE ATT&CK Reference     | T1078 (Valid Accounts)                                                                                                                                                               |
| Business / Security Impact | If temporary role credentials were stolen, broader S3 permissions would increase the amount of data the attacker could attempt to access. Restricting the role reduces blast radius. |
| Severity / Impact          | High                                                                                                                                                                                 |
| Evidence Reference         | PhaseD_RestrictedPolicy.json                                                                                                                                                         |

#### Finding 3: SSE-KMS object required additional decrypt authorization

|                            |                                                                                                                                                                                                       |
|----------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Finding Title              | SSE-KMS object required additional decrypt authorization                                                                                                                                              |
| Type / Category            | Access Control / Encryption Dependency                                                                                                                                                                |
| Cloud Service / Resource   | Amazon S3 secure-s3-lab-sk / AWS KMS                                                                                                                                                                  |
| Description                | A GetObject attempt for text.txt reached S3 but failed with AccessDenied because EC2LabRole was not authorized for kms:Decrypt on the customer-managed KMS key.                                       |
| How Identified             | aws s3 cp s3://secure-s3-lab-sk/text.txt -                                                                                                                                                            |
| MITRE ATT&CK Reference     | N/A — authorization dependency rather than a direct ATT&CK technique                                                                                                                                  |
| Business / Security Impact | Legitimate workloads can fail even when S3 permissions are correct if encrypted objects require KMS permissions. Adding kms:Decrypt must be scoped carefully to avoid expanding access unnecessarily. |
| Severity / Impact          | Medium                                                                                                                                                                                                |
| Evidence Reference         | Phase D CLI observation (kms:Decrypt AccessDenied)                                                                                                                                                    |



## 5.0 Risk Assessment & Cloud Threat Model

The risk assessment below maps each lab observation to preventative and detective controls appropriate to EC2 instance identity and IAM governance.

### 5.1 Cloud Security Control Gaps & Defensive Coverage

| Finding / Gap                   | Observable / Trigger in Cloud Telemetry                                | Recommended Control                                                              | AWS Service / Tool for Implementation             |
|---------------------------------|------------------------------------------------------------------------|----------------------------------------------------------------------------------|---------------------------------------------------|
| IMDS credential exposure risk   | Metadata option changes; unusual use of role credentials in CloudTrail | Require IMDSv2; apply least privilege; remediate SSRF in applications            | EC2 metadata options, IAM, CloudTrail / GuardDuty |
| Broad S3 role permissions       | IAM policy changes; S3 API activity beyond workload needs              | Use resource-scoped policies, permissions boundaries, and periodic access review | IAM, IAM Access Analyzer, AWS Organizations       |
| S3/KMS authorization dependency | KMS Decrypt AccessDenied events and failed S3 object reads             | Grant kms:Decrypt only when required and only to the specific approved KMS key   | AWS KMS key policy / IAM policy / CloudTrail      |

### 5.2 Risk Exposure Over Time

The most important risks over time are credential theft through metadata abuse, excessive permissions attached to the instance role, and unnecessary administrative network exposure.

Risk 1 — Metadata credential exposure:

If application SSRF or similar request-forgery weaknesses remain unresolved, an attacker may attempt to reach EC2 metadata and obtain temporary role credentials. IMDSv2 reduces this attack path but should be combined with application-layer SSRF prevention and minimal IAM permissions.

Risk 2 — Excessive instance-role permissions:

A broadly permissioned instance role increases the impact of any credential compromise. Replacing AmazonS3ReadOnlyAccess with a resource-scoped GetObject permission limits the amount of S3 data exposed to the workload and therefore reduces potential blast radius.

Risk 3 — Administrative exposure and authorization complexity:

Leaving SSH open would add an unnecessary remote-access path when Session Manager is available. Separately, the KMS denial showed that encrypted-data access must be designed across both S3 and KMS policies; permissions should be sufficient for the workload but no broader.

## 6.0 Recommendations

Recommendations below directly address the findings observed in this EC2 identity-protection lab.

### 6.1 Technical Remediation

| # | Finding                          | Specific Remediation Action (with Policy / CLI where applicable)                                                                                                                                                              | Priority   | Standard / Reference                               |
|---|----------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------------|----------------------------------------------------|
| 1 | IMDS credential exposure risk    | Require IMDSv2 on EC2 instances (HttpTokens=required), keep the metadata endpoint only where needed, remediate SSRF in applications, and use least-privilege instance roles.                                                  | Immediate  | AWS EC2 IMDSv2 security guidance / least privilege |
| 2 | Broad S3 read access             | Remove AmazonS3ReadOnlyAccess from EC2LabRole and retain only s3:GetObject for arn:aws:s3:::secure-s3-lab-sk/* where required.                                                                                                | Immediate  | AWS IAM least-privilege principle                  |
| 3 | SSE-KMS authorization dependency | If the workload must read SSE-KMS objects, grant kms:Decrypt only for the specific approved KMS key and ensure the key policy also permits the role. Otherwise use an object/encryption configuration appropriate to the lab. | Short-term | AWS KMS least privilege / separation of duties     |
| 4 | SSH administrative exposure      | Keep inbound TCP/22 absent and administer the instance through Systems Manager Session Manager with appropriate IAM controls and logging.                                                                                     | Immediate  | Secure administrative access / auditability        |

## 6.2 Strategic & Operational Improvements

At an organisational level, the same controls should be made consistent and centrally governed rather than relying on one-off instance configuration.

- Use AWS Organizations Service Control Policies and approved infrastructure-as-code patterns to prevent EC2 deployments that allow IMDSv1 or attach unapproved high-privilege instance roles.
- Standardise EC2 instance profiles and use permissions boundaries so delegated teams cannot expand role permissions beyond approved limits.
- Centralise CloudTrail and security monitoring across accounts to detect role changes, unusual use of temporary credentials, and KMS authorization failures.
- Prefer Systems Manager Session Manager over direct SSH for routine administration, with central IAM access control and session logging where required.
- Review IAM role permissions periodically with IAM Access Analyzer and remove permissions that are not demonstrated as necessary by the workload.

## 7.0 Reflection

---

### Q1 How does enforcing IMDSv2 reduce the attack surface against SSRF vulnerabilities?

Enforcing IMDSv2 requires a session token before EC2 metadata is returned. Unlike IMDSv1, a simple unauthenticated metadata request is not sufficient, which makes many traditional SSRF credential-theft techniques harder to exploit. In this lab, IMDSv2 was configured as required and metadata access used the token-based flow. IMDSv2 is a defense-in-depth control and does not replace fixing SSRF vulnerabilities in the application itself.

### Q2 What business risks arise if an attacker gains temporary credentials from an EC2 instance?

Temporary credentials can be used as valid AWS credentials until they expire and can perform whatever actions the instance role permits. If the role is broad, this can expose cloud data, create operational disruption, increase incident-response costs, and cause compliance concerns. The lab initially used AmazonS3ReadOnlyAccess and later restricted the role to a specific bucket, showing how least privilege reduces the potential blast radius of credential theft.

### Q3 How does replacing SSH with SSM Session Manager improve compliance posture?

Session Manager allows administrators to reach EC2 without exposing inbound SSH port 22 or relying on individually managed SSH keys. In this lab, the instance used AmazonSSMManagedInstanceCore and administration was performed through Session Manager. This supports centralized IAM-based access and can improve auditability while reducing the network attack surface. It also makes access-control reviews easier because administrative access can be governed through AWS identities and policies.

### Q4 If you were designing a multi-account environment, how would you centralize control over instance roles?

I would use AWS Organizations to establish account-level guardrails and Service Control Policies that restrict unapproved IAM and EC2 configuration changes. Standard instance roles would be deployed through centrally managed infrastructure-as-code, with permissions boundaries limiting delegated administrators. CloudTrail and security monitoring would be centralized so role changes and unusual credential use could be reviewed across accounts. This approach keeps workload permissions consistent while still allowing individual accounts to operate within approved limits.



## 8.0 Deliverables Submission Checklist

Deliverables are marked Complete only where the required evidence is known to have been produced or identified. Items not supplied in the conversation are marked Pending for final verification.

| ✓ | Phase   | Deliverable Description                                      | Your Filename                        | Status   |
|---|---------|--------------------------------------------------------------|--------------------------------------|----------|
| ✓ | Phase A | Theory evidence — EC2 identity/IMDSv2 flow diagram           | PhaseA_EC2_IdentityFlow.png          | Complete |
| ✓ | Phase B | Environment setup evidence — instance metadata configuration | PhaseB_IMDSv2_Required.png           | Complete |
| ☐ | Phase C | Core execution evidence — successful S3 listing output       | PhaseC_S3_ReadOnly_Test.png          | complete |
| ✓ | Phase D | Least-privilege S3 IAM policy                                | PhaseD_RestrictedPolicy.json         | Complete |
| — | Phase E | Hosted lab completion                                        | N/A                                  | pending  |
| ✓ | Report  | Final internship task report                                 | CSE_CSE-AWS-L-017-04_SK_20260830.pdf | Complete |

### Submission naming convention:

- Report PDF: CSE\_CSE-AWS-L-017-04\_SK\_20260830.pdf
- Evidence folder: CSE-AWS-L-017-04\_Evidence\_SK/ — include the verified Phase A-D evidence files.

## 9.0 Additional Observations

---

Two troubleshooting observations were significant during the task:

- The EC2 instance initially had no IAM role attached. This was corrected through EC2 > Actions > Security > Modify IAM role, after which EC2LabRole appeared in the instance Security details.
- An S3 GetObject test first returned 404 because the requested key was test.txt while the actual object was text.txt. After correcting the key, the request returned AccessDenied for kms:Decrypt, revealing that the object used a customer-managed KMS key and required additional KMS authorization.
- The KMS error was treated as a layered authorization finding, not as proof that the restricted S3 policy failed. A clean Phase C successful S3 listing screenshot still needs to be verified for submission.
- Session Manager provided a practical alternative to SSH and supported the hardening objective without opening TCP/22.

Before submission, verify the AWS region and all evidence filenames, and redact account IDs or credential values visible in screenshots.

## Declaration & Sign-Off

I confirm that:

- All work in this report is my own except where AI usage is explicitly declared in Section 2.3.
- All technical activities were performed exclusively within the authorised cloud environments listed in Section 1.3.
- No external AWS accounts, production environments, third-party cloud resources, or real customer data were accessed during this task.
- All AWS credentials, access keys, session tokens, and account identifiers used during this task have been redacted in evidence files before submission.
- I have reviewed this report for accuracy, completeness, and professional presentation before submission.

| Intern Full Name | Signature        | Date of Submission |
|------------------|------------------|--------------------|
| Sukhmandeep Kaur | Sukhmandeep kaur | 30 August 2026     |

**EncryptEdge Labs Limited — Junior Cloud Security Engineer Internship Programme**

Company No. 15830711 | United Kingdom | [encryptedgelabs.com](https://encryptedgelabs.com)

*Copyright © 2026 EncryptEdge Labs. All rights reserved. | Report Template v3.0*